

CISM CERTIFICATION EXAM SIMULATOR

Practice Exam 22

Domain II - Information Security Risk Management

30 Questions	48 Minutes	Single Best Answer Format
-----------------	---------------	------------------------------

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

Instructions

- Allow approximately 48 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

Questions

Question 1 (CISM6-028)

Which statement BEST describes residual risk?

- A. The maximum exposure the organization can absorb
- B. The exposure before any controls
- C. The exposure remaining after current controls are considered
- D. The desired exposure after future treatment

Question 2 (CISM6-029)

Which statement about risk appetite and risk capacity is MOST accurate?

- A. Appetite and capacity are always equal
- B. Appetite should remain within the organization's practical capacity to absorb loss
- C. Capacity is set independently by the security team
- D. A high appetite removes the need for tolerance limits

Question 3 (CISM6-030)

Scenario: Two merging insurers use different impact scales, acceptance authorities, and outage tolerances. Leadership requests one combined risk register before integration planning.

What should the information security manager do FIRST?

- A. Adopt the acquiring company's highest scores
- B. Align objectives, definitions, thresholds, time horizons, and decision authority before aggregation
- C. Combine the registers without changing definitions
- D. Average every rating

Question 4 (CISM6-031)

Scenario: A food-delivery company classifies its internal name-resolution service as medium criticality. Mapping shows that ordering, dispatch, driver payments, and customer support all fail when the service is unavailable.

Which assessment conclusion is BEST?

- A. The service remains medium because it stores no customer records
- B. Every network service should receive the same rating
- C. Only ordering should be assessed because it generates revenue
- D. Criticality should reflect the simultaneous impact across dependent business processes

Question 5 (CISM6-032)

Scenario: A retailer uses separate cloud vendors for checkout, loyalty, and inventory. All three host the retailer's workloads in facilities dependent on the same regional power grid.

Which risk should be assessed explicitly?

- A. A regional event causing correlated failure across otherwise separate services
- B. Guaranteed data loss at every vendor
- C. Different vendor invoice cycles
- D. Higher inherent risk solely because cloud services are used

Question 6 (CISM6-033)

Scenario: A payment application depends on a small open-source component maintained by one volunteer. Updates enter production automatically, and the company does not verify signatures or maintain an alternative.

Which scenario is MOST important?

- A. A compromised or abandoned component affects payment integrity and availability
- B. Developers prefer a different programming style
- C. The component has no annual license fee
- D. The volunteer does not attend company meetings

Question 7 (CISM6-034)

What MOST improves consistency in a qualitative risk assessment?

- A. Allowing each assessor to define high impact independently
- B. Using only vulnerability counts
- C. Selecting the highest score whenever evidence differs
- D. Providing defined likelihood and impact criteria with examples and evidence expectations

Question 8 (CISM6-035)

Scenario: A manufacturing service is valued at \$750,000. A disruptive event would affect 40% of its value and is expected 0.2 times per year.

What is the annualized loss expectancy?

- A. \$30,000
- B. \$150,000
- C. \$60,000
- D. \$300,000

Question 9 (CISM6-036)

Scenario: A legal firm identifies active credential phishing, weak recovery verification, and potential disclosure of privileged case files.

How should these elements be classified?

- A. Phishing is the impact, weak verification is the threat, and disclosure is the vulnerability
- B. Phishing is the threat, weak verification is the vulnerability, and disclosure is the impact
- C. All three are controls
- D. Phishing is residual risk and disclosure is a control deficiency

Question 10 (CISM6-037)

Scenario: Two entries describe the same research network as high and low risk. Neither records its date, scope, control assumptions, or owner.

What should the information security manager do FIRST?

- A. Keep the high value
- B. Average the ratings
- C. Close both entries
- D. Reconcile and document the assessment

Question 11 (CISM6-038)

Scenario: A company wants an autonomous software agent to approve refunds and change customer records. The pilot evaluated response quality but not excessive authority, manipulation, auditability, or provider retention.

What is the PRIMARY assessment gap?

- A. Authority, manipulation, accountability, logging, data use, and provider scenarios were omitted
- B. The agent's interface color was not tested
- C. Automation always makes inherent risk low
- D. Refund volume was not compared with employee headcount

Question 12 (CISM6-039)

Scenario: Two exposures have equal scores. One could prevent a mandatory filing due next week; the other affects an internal catalog with a tested workaround and no deadline.

Which exposure should be prioritized?

- A. Neither because scores match
- B. The catalog because internal systems are easier to fix
- C. The filing exposure because its deadline and obligation increase urgency
- D. Whichever has more technical findings

Question 13 (CISM6-040)

Scenario: A cyber-loss estimate changes substantially when event frequency moves within its plausible range.

What is the MOST useful management conclusion?

- A. The model should be discarded
- B. Disclose ranges, evidence quality, and sensitivity to frequency assumptions
- C. Technical severity should replace frequency
- D. The highest result is guaranteed

Question 14 (CISM6-041)

Scenario: A hospital rates recovery risk low because workstation backups are tested monthly. The assessed scenario concerns a clinical database that has never been restored in testing.

Which conclusion is BEST?

- A. Inherent risk is low
- B. Residual risk may be understated by irrelevant control evidence
- C. Test frequency proves database recovery
- D. The rating should be accepted automatically

Question 15 (CISM6-042)

Scenario: A board must decide whether to fund resilience for an emergency-notification service. It receives technical findings but no business scenario, assumptions, or treatment comparison.

What should be presented FIRST?

- A. The material disruption scenario, exposure against appetite, assumptions, and response options
- B. Assessment hours
- C. All findings sorted by scanner score
- D. A request to buy every available control

Question 16 (CISM6-043)

Which action BEST represents risk mitigation?

- A. Stopping the activity
- B. Purchasing insurance
- C. Formally retaining exposure
- D. Implement a risk-reducing control

Question 17 (CISM6-044)

Who should formally accept residual information security risk?

- A. The authorized business risk owner
- B. The assessor
- C. The control operator
- D. The external auditor

Question 18 (CISM6-045)

Scenario: A small gallery considers an optional public scripting feature. Expected benefit is negligible, required safeguards exceed that benefit, and untreated risk is far above appetite.

Which response is MOST appropriate?

- A. Launch and observe attacks
- B. Accept because use is optional
- C. Remove scripting from the feature
- D. Transfer accountability to visitors

Question 19 (CISM6-046)

Scenario: A customer platform cannot meet a binding security obligation before launch. The product owner offers to accept the risk, but policy provides no authority to waive the duty.

What is the BEST action?

- A. Record acceptance and launch
- B. Implement compliant treatment or change the launch
- C. Buy insurance
- D. Ask developers to accept it

Question 20 (CISM6-047)

Scenario: Two controls reduce refund-fraud risk within tolerance. Control X costs more and delays legitimate refunds; Control Y meets obligations without material delay.

Which should be recommended?

- A. Control X because cost proves strength
- B. Control Y balances risk, cost, and impact
- C. Both regardless of benefit
- D. Neither because risk remains

Question 21 (CISM6-048)

Scenario: A publisher discovers after contract signature that a vendor will use an unreviewed transcription subcontractor. Security review normally occurs during implementation.

Which process change is MOST effective?

- A. Require risk-tiered data and subcontractor review
- B. Ban every subcontractor
- C. Review after launch
- D. Let procurement accept every risk

Question 22 (CISM6-049)

Which characteristic BEST distinguishes a useful key risk indicator?

- A. It counts all security-team activities
- B. It always measures realized financial loss
- C. It provides timely evidence that exposure is approaching or exceeding a defined threshold
- D. It replaces the need for risk assessment

Question 23 (CISM6-050)

Scenario: A municipal payment project has an above-tolerance privacy risk, but its treatment has no owner, funding, or release criterion.

What is the BEST corrective action?

- A. Move it to a postlaunch backlog
- B. Ask developers to accept it
- C. Fund treatment and require acceptable residual-risk evidence at release
- D. Lower the rating

Question 24 (CISM6-051)

Scenario: A power plant cannot patch a certified controller. Segmentation is proposed, but testing reveals a vendor modem that bypasses the segmented path.

What should the information security manager do FIRST?

- A. Approve because segmentation exists
- B. Accept for the plant
- C. Ignore the modem
- D. Reassess coverage and residual risk before exception approval

Question 25 (CISM6-052)

Scenario: A temporary acceptance requires failed transactions to remain below 1%. The rate reaches 4% for two reporting periods, meeting the review trigger.

What should happen NEXT?

- A. Raise the threshold retroactively
- B. Invoke reassessment and a revised owner decision
- C. Wait for customer loss
- D. Close the risk because monitoring worked

Question 26 (CISM6-053)

Scenario: A 60-day authentication exception has been renewed five times. Its compensating control was never tested, and the original approver left the company.

What is the BEST action?

- A. Renew automatically
- B. Make it permanent
- C. Reassess exposure and controls
- D. Close the exception

Question 27 (CISM6-054)

Scenario: Due diligence assumed an acquired service would remain separate for nine months. Management now plans immediate connection to customer identity and finance systems.

What is the MOST appropriate action?

- A. Use the old rating
- B. Connect and monitor
- C. Ask the seller to accept risk
- D. Reassess trust, data flows, controls, and aggregate impact

Question 28 (CISM6-055)

Scenario: Eight units delay replacing the same vulnerable appliance. Each delay is locally approved, but all units support one major customer and depend on one support team. Aggregate exposure exceeds appetite.

What should be reported?

- A. Only the oldest appliance
- B. Nothing until local tolerance is exceeded
- C. Only technical severity
- D. Aggregate concentration, local decisions, trend, and required action

Question 29 (CISM6-056)

Scenario: A ticket marketplace must reduce bot fraud before a major sale. One control reaches tolerance in ten days with minor friction; a more convenient control needs four months. Costs are comparable.

Which response is BEST?

- A. Deploy before the sale
- B. Accept informally
- C. Deploy neither
- D. Wait four months

Question 30 (CISM6-057)

Scenario: Executives receive hundreds of overdue tasks but cannot tell whether supplier exposure is rising or what action they must authorize.

Which reporting approach is MOST appropriate?

- A. Material risk, treatment, exceptions, and decisions
- B. Add every raw task
- C. Report only spending
- D. Wait until all tasks close

Answer Key

Domain II - Information Security Risk Management

1 C	2 B	3 B	4 D	5 A
6 A	7 D	8 C	9 B	10 D
11 A	12 C	13 B	14 B	15 A
16 D	17 A	18 C	19 B	20 B
21 A	22 C	23 C	24 D	25 B
26 C	27 D	28 D	29 A	30 A

Detailed Explanations

Question 1 (CISM6-028)

Correct answer: C - The exposure remaining after current controls are considered

Residual risk is the exposure remaining with current controls. Inherent risk is assessed before controls, capacity is the maximum sustainable exposure, and target risk is the desired post-treatment state.

Question 2 (CISM6-029)

Correct answer: B - Appetite should remain within the organization's practical capacity to absorb loss

An organization may choose its appetite, but that choice should remain within its ability to absorb exposure. Security does not independently set capacity, the concepts are not necessarily equal, and tolerance still translates appetite into practical limits.

Question 3 (CISM6-030)

Correct answer: B - Align objectives, definitions, thresholds, time horizons, and decision authority before aggregation

Comparable results require a common context and approved criteria before aggregation. Choosing higher values or averaging incompatible scores introduces bias, while combining different definitions creates misleading enterprise results.

Question 4 (CISM6-031)

Correct answer: D - Criticality should reflect the simultaneous impact across dependent business processes

The shared service creates a broad availability dependency, so its rating should reflect aggregate business impact. Data storage is not the only source of criticality, excluding other processes understates exposure, and ratings still depend on context.

Question 5 (CISM6-032)

Correct answer: A - A regional event causing correlated failure across otherwise separate services

The common regional dependency creates concentration risk that individual vendor reviews may miss. Invoice timing is not the stated security issue, failure is not guaranteed, and cloud use alone does not establish higher inherent risk.

Question 6 (CISM6-033)

Correct answer: A - A compromised or abandoned component affects payment integrity and availability

Unverified automatic updates and single-maintainer dependency create compromise and abandonment scenarios affecting a critical application. Style, price, and meeting attendance do not represent the material exposure.

Question 7 (CISM6-034)

Correct answer: D - Providing defined likelihood and impact criteria with examples and evidence expectations

Defined criteria, examples, and evidence expectations reduce variation in expert judgment. Personal definitions, vulnerability counts, and automatic escalation do not create comparable business-risk assessments.

Question 8 (CISM6-035)

Correct answer: C - \$60,000

Single loss expectancy is \$750,000 multiplied by 40%, or \$300,000. Multiplying by the annual rate of 0.2 gives an annualized loss expectancy of \$60,000.

Question 9 (CISM6-036)

Correct answer: B - Phishing is the threat, weak verification is the vulnerability, and disclosure is the impact

Phishing is threat activity, weak verification is an exploitable condition, and disclosure is a business consequence. The alternatives reverse these concepts or classify them incorrectly.

Question 10 (CISM6-037)

Correct answer: D - Reconcile and document the assessment

A common scenario and traceable evidence are required before choosing a rating. Keeping or averaging unsupported scores does not resolve the conflict, while closure would hide the exposure.

Question 11 (CISM6-038)

Correct answer: A - Authority, manipulation, accountability, logging, data use, and provider scenarios were omitted

An agent able to take business actions requires assessment of authority, manipulation, auditability, accountability, and data handling. Interface design and headcount do not cover these risks, and automation does not imply low exposure.

Question 12 (CISM6-039)

Correct answer: C - The filing exposure because its deadline and obligation increase urgency

The imminent mandatory filing creates greater decision urgency despite equal summary scores. Ease of remediation and finding counts do not determine business priority, and matching scores can conceal timing differences.

Question 13 (CISM6-040)

Correct answer: B - Disclose ranges, evidence quality, and sensitivity to frequency assumptions

Sensitivity indicates which assumption strongly influences the result and should be transparent to decision-makers. It does not invalidate the model, guarantee a maximum, or justify substituting technical severity.

Question 14 (CISM6-041)

Correct answer: B - Residual risk may be understated by irrelevant control evidence

Control evidence must match the asset and scenario in scope. Workstation tests do not prove database recovery, do not lower inherent risk, and cannot support automatic acceptance.

Question 15 (CISM6-042)

Correct answer: A - The material disruption scenario, exposure against appetite, assumptions, and response options

The board needs business impact, appetite comparison, assumptions, and response choices. Technical detail and effort do not establish materiality, and buying every control ignores proportionality.

Question 16 (CISM6-043)

Correct answer: D - Implement a risk-reducing control

Mitigation reduces likelihood or impact through controls. Stopping is avoidance, insurance shares financial consequences, and retaining exposure is acceptance.

Question 17 (CISM6-044)

Correct answer: A - The authorized business risk owner

Acceptance is a business decision for the authorized risk owner. Assessors, control operators, and auditors provide evidence or execution but do not automatically own the business consequence.

Question 18 (CISM6-045)

Correct answer: C - Remove scripting from the feature

Removing the optional capability avoids high exposure with little value. Optional status does not justify acceptance, user terms cannot transfer accountability, and launching first leaves risk unmanaged.

Question 19 (CISM6-046)

Correct answer: B - Implement compliant treatment or change the launch

A mandatory duty cannot be waived through ordinary acceptance. Legal and authorized leadership must secure compliance or change the launch; insurance and developer approval do not remove the obligation.

Question 20 (CISM6-047)

Correct answer: B - Control Y balances risk, cost, and impact

Control Y meets the risk objective with better business value. Higher cost does not prove effectiveness, both controls are not justified, and acceptable residual risk need not be zero.

Question 21 (CISM6-048)

Correct answer: A - Require risk-tiered data and subcontractor review

Early review preserves options to select, negotiate, treat, or seek authorized acceptance. Later review loses leverage, a universal ban is disproportionate, and procurement lacks automatic authority for all risk.

Question 22 (CISM6-049)

Correct answer: C - It provides timely evidence that exposure is approaching or exceeding a defined threshold

A useful KRI signals movement in exposure against defined limits early enough to act. Activity counts may be operational metrics, realized loss is not always required, and indicators complement rather than replace assessment.

Question 23 (CISM6-050)

Correct answer: C - Fund treatment and require acceptable residual-risk evidence at release

Ownership, funding, and a release criterion integrate treatment into delivery governance. A later backlog is too late, developers may lack business authority, and changing the rating does not reduce exposure.

Question 24 (CISM6-051)

Correct answer: D - Reassess coverage and residual risk before exception approval

The bypass undermines the compensating control, so its coverage and residual exposure require reassessment. Control presence does not prove effectiveness, security should not accept business risk, and the modem is part of the scenario.

Question 25 (CISM6-052)

Correct answer: B - Invoke reassessment and a revised owner decision

The approved trigger requires reassessment and a new response decision. Raising it conceals exposure, waiting defeats the indicator, and effective monitoring does not close the risk.

Question 26 (CISM6-053)

Correct answer: C - Reassess exposure and controls

Repeated renewal, untested compensation, and changed authority require fresh assessment and approval. Automatic renewal, closure, or permanent acceptance would lack current evidence and authority.

Question 27 (CISM6-054)

Correct answer: D - Reassess trust, data flows, controls, and aggregate impact

Immediate integration invalidates the isolation assumption and creates new exposure paths. The prior rating no longer fits, postconnection monitoring is late, and the seller cannot own the buyer's risk.

Question 28 (CISM6-055)

Correct answer: D - Aggregate concentration, local decisions, trend, and required action

The shared customer and support dependencies create enterprise exposure hidden by local approvals. Reporting one asset or only severity loses context, while waiting ignores the appetite breach.

Question 29 (CISM6-056)

Correct answer: A - Deploy before the sale

The timely control addresses exposure before the critical event while allowing later improvement. Waiting or informal acceptance leaves risk above tolerance, and minor friction does not justify rejecting treatment.

Question 30 (CISM6-057)

Correct answer: A - Material risk, treatment, exceptions, and decisions

Executive reporting should connect material exposure to appetite, show treatment effectiveness and exceptions, and identify decisions. Raw tasks and spending lack outcome context, while delay prevents timely oversight.